

CTFCU Quantitative Risk Register

Prepared by Giuseppe Scalzo · ISO 27001 Lead Auditor · GRC Capstone Engagement

Purpose	Authoritative record of all identified information security risks at CTFCU. Each risk is scored, owned, treated, and reviewed quarterly.
Framework	ISO/IEC 27001:2022 Clause 6.1 (Risk Treatment), aligned to NIST SP 800-30 and ISO/IEC 27005.
Scoring	Likelihood (1–5) × Impact (1–5). Residual = score after existing controls. Inherent = score with no controls.
Risk Levels	1–2 Very Low 3–4 Low 5–9 Medium 10–14 High 15–19 Very High 20–25 Critical

Sheets in this Workboo

- | | |
|------------------|---|
| • Risk Register | All 15 identified risks with full scoring, ownership, controls, and treatment |
| • Treatment Plan | Action plan and cost roll-up for risks above appetite |
| • Heatmap | Visual 5×5 likelihood-by-impact matrix |

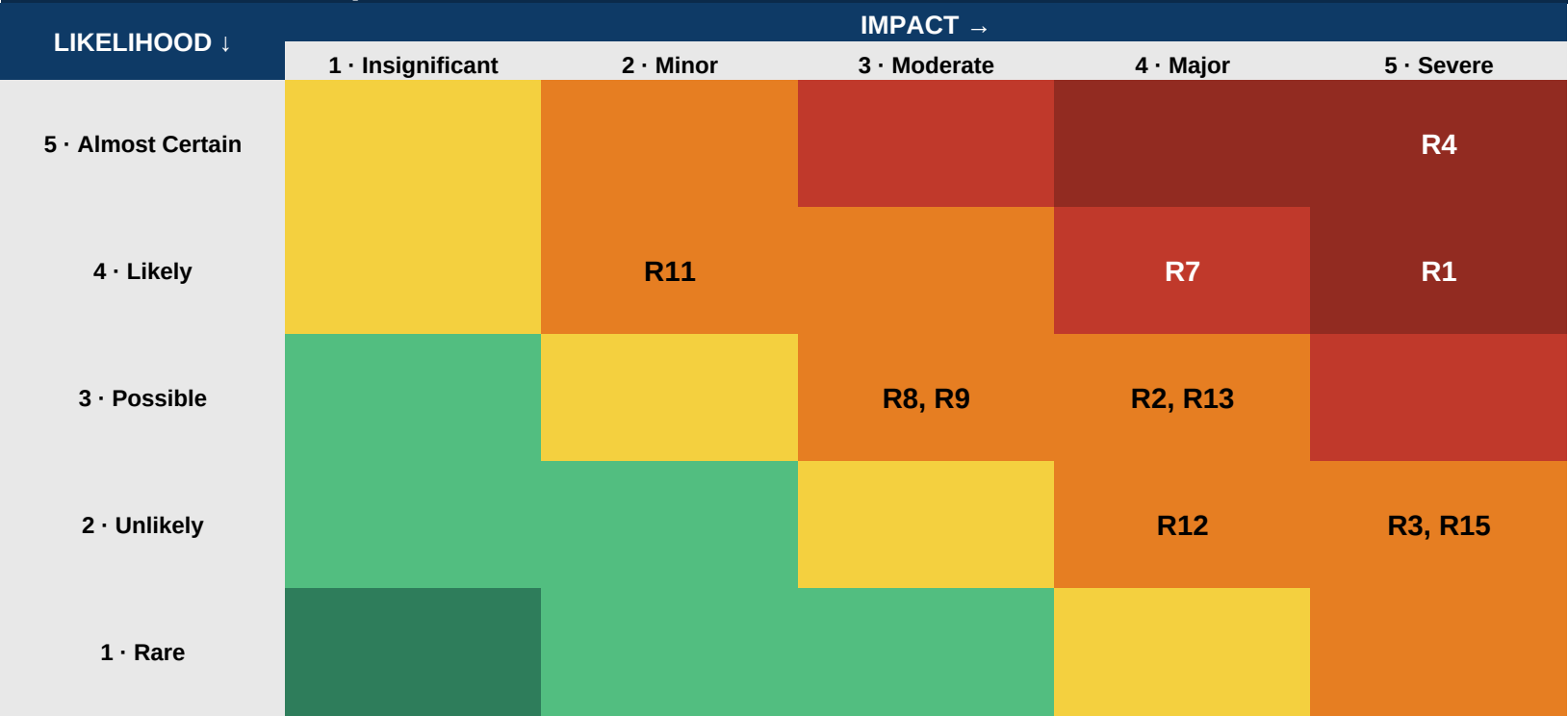
Engagement Context	Cumberland Trust Federal Credit Union — \$2B regional credit union (TN/KY/AL). Phishing incident Q1 2026 triggered NCUA examination findings and a Board-authorized 18-month GRC program build aligned to NIST CSF 2.0 and ISO 27001:2022.
---------------------------	--

Risk ID	Risk Title	Category	Asset(s) Affected	Threat	Vulnerability	Inherent L	Inherent I	Inherent Score	Existing Controls	Residual L	Residual I	Residual Score	Residual Rating	Risk Owner	Treatment Decision	Treatment Action	Annex A Controls	CSF Subcategories
R-01	Ransomware Attack on Production Systems	Cyber — Avail+Conf	Tier 1 & 2 systems; data warehouse; backups	T-D1 Ransomware; T-I1 Data Exfiltration	Inconsistent patching; MFA gaps on admin; no SIEM	5	5	25	Defender for Endpoint; daily backup; weekly offline copy	4	5	20	Critical	CIO	Mitigate	Deploy SIEM (M8); enforce MFA admin (M5); immutable backups (M6); phishing-resistant MFA (M10)	A.5.7, A.5.23, A.5.24, A.8.7, A.8.8, A.8.13, A.8.16	PR.AA, PR.DS, PR.IR, DE.CM, RS.CO, RC.RP
R-02	Insider Threat — Privileged User Abuse	Cyber+Behavioral	Core banking; member master data; HRIS	T-E4 Privilege abuse; T-I6 Insider exfiltration	No JML process; no access reviews; no UEBA	3	5	15	Background checks; basic logging on core systems	3	4	12	High	CIO + HR	Mitigate	PAM platform (M9); quarterly access reviews (M4); UEBA via SIEM (M10); BTAT activation (M3)	A.5.15, A.5.16, A.5.18, A.6.2, A.6.7, A.8.2, A.8.18	GV.OC, GV.RR, PR.AA, DE.CM
R-03	Backup Failure During Recovery	Cyber — Availability	Backup repository; recovery capability	T-D1 Ransomware; T-T4 Backup tampering	Backups on prod domain; no offline copy; restore not tested	2	5	10	Daily backup; weekly offline copy	2	5	10	High	IT Ops Mgr	Mitigate	Immutable backup tier (M6); quarterly restore drill (M7); air-gapped Tier 1 (M8)	A.8.13, A.8.14	PR.DS-11, RC.RP-2
R-04	Phishing-Driven Credential Compromise	Cyber — Conf+Integrity	Employee identities; M365 tenant; SSO downstream	T-S1 Phishing; T-S4 BEC	Inconsistent MFA on admin; informal training; no simulation	5	4	20	MFA on online banking; M365 spam filter	5	4	20	Critical	InfoSec Mgr	Mitigate	MFA all admin (M5); phishing-resistant MFA pilot (M10); monthly phishing sim (M4); awareness platform (M4); Defender for Office 365 (M4)	A.6.3, A.8.5, A.8.16	PR.AA, PR.AT, DE.CM
R-05	GLBA Safeguards Rule Non-Compliance	Compliance	Member NPI; compliance posture	Regulatory action; civil penalties	No formal infosec program; no Qualified Individual	4	4	16	None specific to GLBA Safeguards	2	4	8	Medium	Compliance Officer + CIO	Mitigate	Complete ISMS by M6; GLBA crosswalk M4; designate Qualified Individual M3	A.5.1, A.5.31, A.5.32, A.5.34	GV.OC, GV.PO, GV.OV
R-06	Open NCUA Document of Resolution Items	Regulatory	Regulatory standing	Escalated NCUA enforcement; CAMELS impact	Six open DOR items from May 2026 examination	5	4	20	Active remediation engagement (this program)	2	4	8	Medium	CEO	Mitigate	DOR remediation tracker maintained by Compliance; quarterly reports to NCUA	Cross-cutting	GV.OC-3, GV.OV
R-07	Critical Third-Party Compromise	Cyber — Conf+Avail	All data dependent on affected vendor	T-I4 Vendor compromise	No formal TPRM; SOC 2 reports not consistently obtained	4	5	20	Contractual review by Legal at onboarding	4	4	16	Very High	CRO	Mitigate+Transfer	TPRM program (M5-M10); SOC 2/ISO 27001 evidence; incident notification SLAs; cyber insurance	A.5.19, A.5.20, A.5.21, A.5.22, A.5.23	GV.SC, ID.SC
R-08	Unpatched Critical Vulnerabilities	Cyber — CIA	On-prem servers; workstations; network devices	T-E1 Exploitation of vulnerability	No patch SLAs; CISA KEV items unpatched > 30 days	4	4	16	Quarterly Tenable scans (no remediation tracking)	3	4	12	High	IT Ops Mgr	Mitigate	VM Policy (M4); patch SLAs (14/30/60); monthly KPI reporting; KEV-driven emergency patching	A.8.7, A.8.8, A.8.9	ID.RA, PR.IP
R-09	ATM Skimming and Physical Tampering	Physical+Cyber	38 ATMs; cardholder data	T-P2 ATM attack; T-T5 Physical tampering	No anti-skim hardware on 14 of 38 ATMs	4	3	12	Vendor-managed; surveillance at HQ ATMs only	3	3	9	Medium	ATM Ops Mgr	Mitigate	Anti-skim retrofit (M6-M9); 24/7 monitoring; behavioral analytics from card network	A.7.1, A.7.4, A.7.8	PR.AA-6, PR.IR-2
R-10	DDoS Against Online Banking	Cyber — Availability	Online banking; member website	T-D2 DDoS	DDoS protection at provider edge only	3	3	9	Vendor-provided DDoS protection on online banking	2	3	6	Medium	CIO	Mitigate	Verify provider scope (M4); add edge DDoS protection on website (M7); DDoS playbook + tabletop	A.8.6	PR.IR-3, DE.AE
R-11	Lost or Stolen Unencrypted Mobile Device	Cyber — Confidentiality	Corporate laptops; corporate mobile phones	T-I2 Lost device	BitLocker not on older laptops; no wipe on 12% mobile	4	2	8	Intune MDM on majority; BitLocker on Win11	4	2	8	Medium	IT Ops Mgr	Mitigate	100% BitLocker enforcement via Intune (M5); legacy laptop retirement (M9); 100% Intune mobile (M6)	A.7.9, A.7.10, A.8.1	PR.DS-3, PR.DS-1
R-12	Branch Robbery	Physical — Safety	Branch personnel; cash; members in branch	T-P1 Robbery	Inconsistent training; no formal robbery refresher	3	4	12	Cash limits; cameras; alarms; barriers at 8 of 15 branches	2	4	8	Medium	Physical Security Mgr	Mitigate	Annual robbery training (M5); barriers at remaining 7 branches (M12); tabletop with local LE	A.7.1, A.7.2, A.7.3, A.7.4	PR.AA-6
R-13	Email Misdirection Disclosing Member NPI	Cyber — Confidentiality	Member NPI	T-I3 Misdirected email	No DLP; no external recipient warning; no encryption	4	3	12	M365 spam filter; informal awareness	3	3	9	Medium	InfoSec Mgr	Mitigate	Purview DLP (M7); external recipient banner (M4); secure portal for member NPI (M8)	A.8.10, A.8.11, A.8.12	PR.DS-5
R-14	Pandemic / Regional Disaster — Workforce Unavailability	Operational	Workforce capacity	T-D5 Natural disaster; T-D6 Pandemic	No documented BC plan; no cross-training matrix	2	4	8	M365 remote work; informal cross-training	2	3	6	Medium	COO	Mitigate	Formal BC plan (M8); cross-training matrix; annual pandemic refresh	A.5.29, A.5.30	RC.RP, ID.BE
R-15	Workplace Violence Incident at Branch or HQ	Physical+Behavioral	Personnel; physical facility; members on-site	T-P4,P5,P6,P8 Workplace violence variants	No WVP program; no BTAT; no DV intrusion protocol	2	5	10	Branch alarms; informal awareness	2	5	10	High	HR Director + Physical Security Mgr	Mitigate	WVP program (M6); BTAT activation (M3); ALICE/CRASE training (M4-M7); local LE coordination	A.6.3, A.7.1, A.7.2	GV.RR, PR.AT, PR.IR

Risk Treatment Plan — Action Tracker

Risk ID	Action	Owner	Target Month	Capital Cost	Annual Operating
R-04	MFA enforced on all admin accounts	InfoSec Mgr	M5	-	-
R-04	Security awareness platform (annual)	InfoSec Mgr	M4	-	\$40,000
R-04	Monthly phishing simulation	InfoSec Mgr	M4	-	-
R-04	Defender for Office 365 (annual)	InfoSec Mgr	M4	-	\$24,000
R-04	Phishing-resistant MFA pilot (FIDO2)	InfoSec Mgr	M10	\$18,000	-
R-01	Immutable backup tier deployment	IT Ops Mgr	M6	\$65,000	-
R-01	SIEM platform deployment	InfoSec Mgr	M8	\$180,000	\$90,000
R-01	Quarterly restoration drills	IT Ops Mgr	M7	-	-
R-07	Cyber insurance (annual)	CFO	M4	-	\$75,000
R-07	TPRM program standup	CRO	M5-M10	-	-
R-02	Privileged Access Management platform	IT Ops Mgr	M9	\$120,000	\$40,000
R-02	BTAT standup (training+materials)	HR Director	M3	\$15,000	-
R-03	Air-gapped backup for Tier 1	IT Ops Mgr	M8	\$45,000	-
R-09	Anti-skimming hardware retrofit	ATM Ops Mgr	M6-M9	\$120,000	-
R-09	24/7 ATM monitoring contract	ATM Ops Mgr	M7	-	\$36,000
R-11	Endpoint refresh (legacy laptop retirement)	IT Ops Mgr	M9	\$80,000	-
R-12	Annual robbery response training	Phys Sec Mgr	M5	-	\$12,000
R-12	Bullet-resistant barriers (7 remaining branches)	Phys Sec Mgr	M12	\$140,000	-
R-13	Microsoft Purview DLP (annual)	InfoSec Mgr	M7	-	\$48,000
R-13	Secure member NPI delivery portal	InfoSec Mgr	M8	-	\$24,000
R-15	ALICE/CRASE training all staff	HR Director	M4-M7	\$28,000	-
R-10	Edge DDoS protection on member site	InfoSec Mgr	M7	-	\$18,000
ISO	ISO 27001 Stage 1 + Stage 2 audit fees	CFO	M16-M18	\$60,000	-
TOTAL				\$871,000	\$407,000

CTFCU Risk Heatmap — Residual Scores



Legend:

